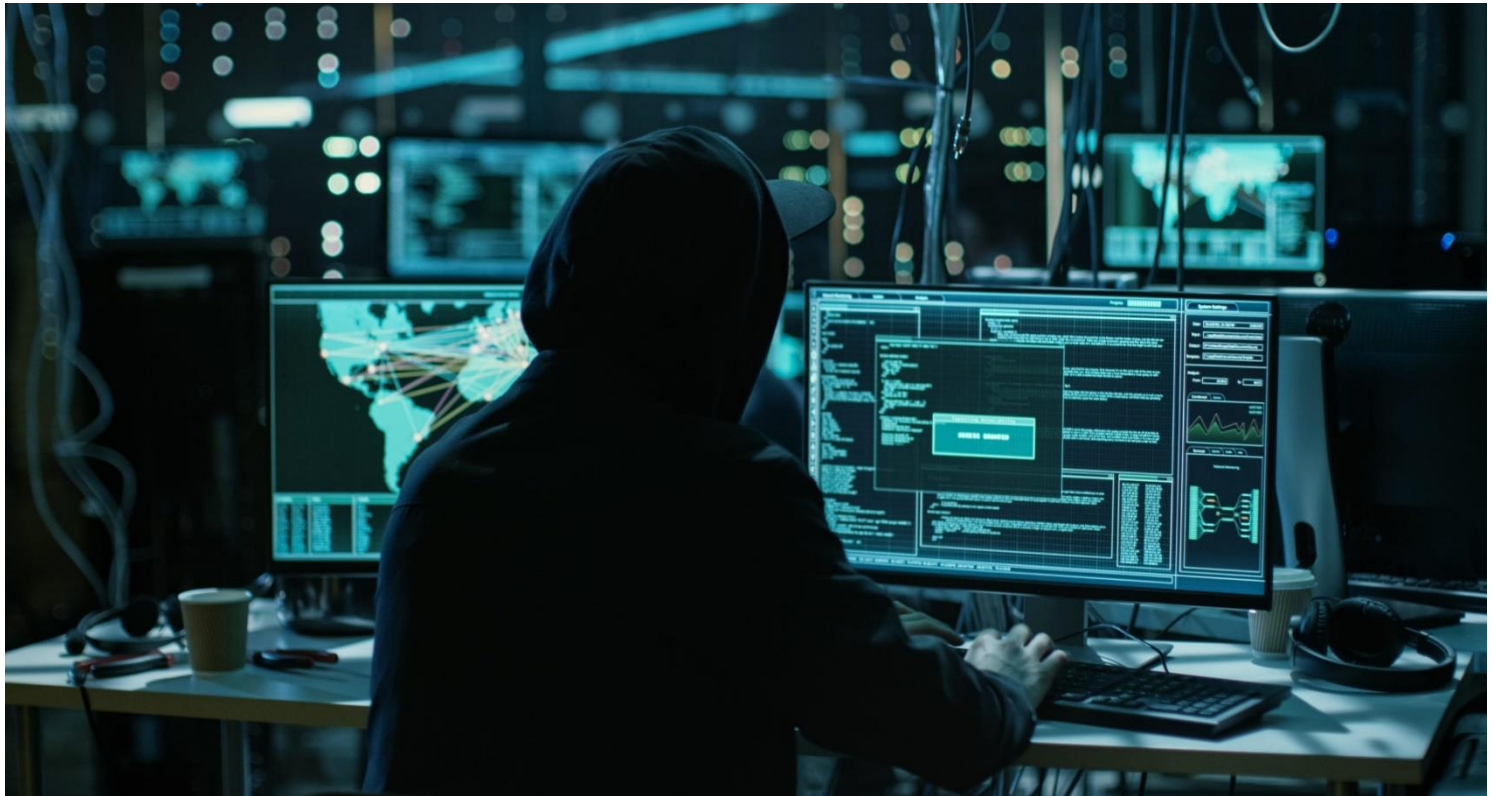




Vulnerability Assessment & Penetration Testing (VAPT)

Report

of IT Landscape at

Betala Stock Broking Limited



PRIME INFOSERV LLP

(A CERT-In Empanelled, ISO 9001:2015 & 27001:2013 Certified Enterprise)
DL 124, 1st Floor, Sector II, Salt Lake, Kolkata -700091, West Bengal, India
Phone: +91 33 4008 5677 | E-Mail: sales@primeinfoserv.com | Web: www.primeinfoserv.com
Cyber-Advisory | Compliance & Audit Services | Managed Security Services

Document Control

Document type	VAPT Report of IT landscape at Betala Stock Broking Limited
Document owner	Prime Infoserv LLP

Authors & Auditors	Mail ID
Kanu Guchhait	kanu@primeinfoserv.com
Rajarshi Roy Chowdhury	rajarshi@primeinfoserv.com

Reviewed & verified by	Mail ID
Sailen Sengupta	ssengupta@primeinfoserv.com

Approved by	Digital Signature
Sushobhan Mukherjee, CISA Certificate No. 21177065	

Revision History		
Version	Date	Description
1.0	21-11-2022	VAPT Report of IT landscape at Betala Stock Broking Limited
1.1	29-11-2022	VAPT Report of IT landscape at Betala Stock Broking Limited

Assessment Information - Auditee			
Client	Betala Stock Broking Limited		
Assessment Type	VAPT Report of IT landscape		
Ref. No. & Date	NIL & 04.11.2022		
Contact Person	Baldev Solanki		
Contact Number	+91 83205 56703	Mail ID	betalastock@yahoo.co.in
Report Date	29-11-2022	Assessment Period	25-11-2022 to 27-11-2022

Notice of Confidentiality

This document contains proprietary and confidential information of Prime Infoserv LLP. The recipient agrees to maintain this information in confidence and not to reproduce or to disclose this information to any person outside of the group directly responsible for the evaluation of its contents. There is no obligation to maintain the confidentiality of any information which was known to the recipient prior to the receipt of this document from Prime Infoserv LLP or which becomes publicly known through no fault of the recipient or is received without obligation of confidentiality from a third party owing no obligation of confidentiality to Prime Infoserv LLP.

Table of Contents

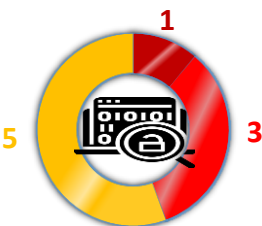
1. Introduction	3
2. Methodology & Approach	4
2.1. Network VAPT Approach	4
3. Assessment Scope	5
3.1. Internet facing IP	5
3.2. Router	5
3.3. Router	5
4. Risk Level & Description	5
5. Tools used during assessment	6
6. Disclaimer & Assumptions	7
8. Executive Summary Report	8
8.1. IP wise vulnerability count	8
9. Detail Report	9
10. About Prime	20
11. Audit Test Standard	20
12. Team Skill Set	20
13. Cert Empanelment	21
14. Contact Us	22

1. Introduction

Betala Stock Broking Limited (BSBL), a trading member of National Stock Exchange of India (NSE), was incorporated on 23rd May, 1995 as a Private Limited Company, and subsequently converted into Public Limited Company on 13th February 1996 and obtained registration from Securities and Exchange Board of India (SEBI) on 20th May, 1996. The Company has a dominant position in both institutional and retail broking. The company has a full fledged research division involved in Macro Economic studies, sectoral research and company specific equity research combined with a strong and well networked sales force which helps deliver current and up to date market information and news. The firm's philosophy is entirely client centric, with a clear focus on providing long term value addition to clients, while maintaining the highest standards of excellence, ethics and professionalism.

Prime Infoserv LLP has conducted the audit of IT landscape of Betala Stock Broking Limited as per mentioned scope and submitted detailed finding in phased manner. This report includes all possible minute details of the outcomes against the scope, along with all significant findings and detailed remediation advice. This summary report provides a synopsis of the key findings and relates these back to business impacts. The report covers not only the identified Gaps, but also the possible recommendations & blueprinting.

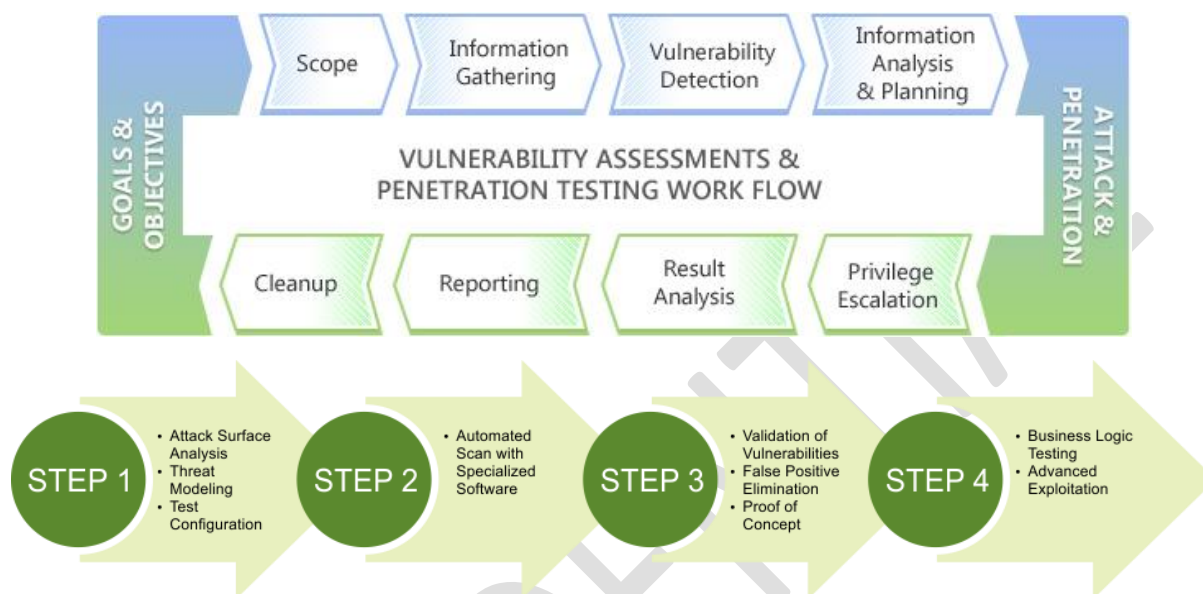
OVERALL VULNERABILITIES

<u>Findings – Initial</u>	<u>Findings – Post Mitigation</u>
 ■ Critical ■ High ■ Medium ■ Low ■ Informational	NIL

2. Methodology & Approach

2.1. Network VAPT Approach

During the conduct phase, the audit team performed VAPT using tools like Nexpose, Nessus, Metasploit, Advanced IP Scanner, GFI Languard, Retina, Acunetix and Fern Wi-Fi Inspector and debriefed on preliminary findings.



In accordance with the audit scope, same has been carried out in three phases: the planning phase, the conduct phase, and the reporting phase.

During the planning phase, the auditors proceeded with a thorough review of documents provided by the Information Technology department. Preliminary interviews were conducted with departmental personnel to gather knowledge of management controls and processes and to identify key risks associated with the Servers, Web applications, and Network devices.

The purpose of the planning phase was to develop a Risk-Based Audit Program that provides a basis for the orderly, efficient, and cost-effective conduct of the audit as well as a criteria base for assessment.

Once the penetration test is done and the root cause of the vulnerabilities is analysed, we give a comprehensive report to the client. It comprises detailed information regarding the vulnerabilities detected in the security assessment, risk rating for each of them, supporting detailed exhibits, and detailed technical remediation recommendations.

For more information about Vulnerability Assessment and Penetration Testing, refer to the link below:
<https://www.guru99.com/vulnerability-assessment-testing-analysis.html>

3. Assessment Scope

3.1. Internet facing IP

Sl. No.	IP Details
1	150.129.107.253
2	103.251.216.117
3	137.128.1.51

3.2. Router

Sl. No.	IP Details
1	10.190.26.113

3.3. Router

Sl. No.	IP Details
1	192.168.1.100
2	192.168.0.22

4. Risk Level & Description

Vulnerability Levels	Description
Critical	Exploitation of the vulnerability may result in complete compromise of the Database server or Application server. It can have a major impact on business. (CVSS Score- 9.0-10)
High	Exploitation of the vulnerability may result in complete compromise of the Application / disclosure of sensitive information. Vulnerability is easily exploitable. (CVSS Score- 7.0-8.9)
Medium	Exploitation of the vulnerability may result in some control on the Application / disclosure of semi-sensitive information. Exploitation of this vulnerability is possible but difficult. (CVSS Score- 4.0-6.9)
Low	Exploitation of the vulnerability may result in little or no impact on the application / disclosure of less sensitive information. Exploitation of this vulnerability is extremely difficult. (CVSS Score- 0.0-3.9)
Informational	The informational risk level indicates that some functionality or component is missing best practices implementation in the application. Such vulnerability may not have a risk associated with it currently, but it may become vulnerability in future due to change in application or due to exploiting techniques evolution or policy/legal requirements. The vulnerability mitigation depends upon owner decision; however, it is recommended to be mitigated if it not in line with the policy or law.

5. Tools used during assessment

We are using various commercial, open source and customized tools to conduct the VAPT, some of which are mentioned below.



CONFIDENTIAL

6. Disclaimer & Assumptions

Disclaimer: This report is intended to provide a detailed overview of the completed IT landscape as per scope mentioned of Betala Stock Broking Limited, which describes the latest findings identified by Prime Infoserv LLP.

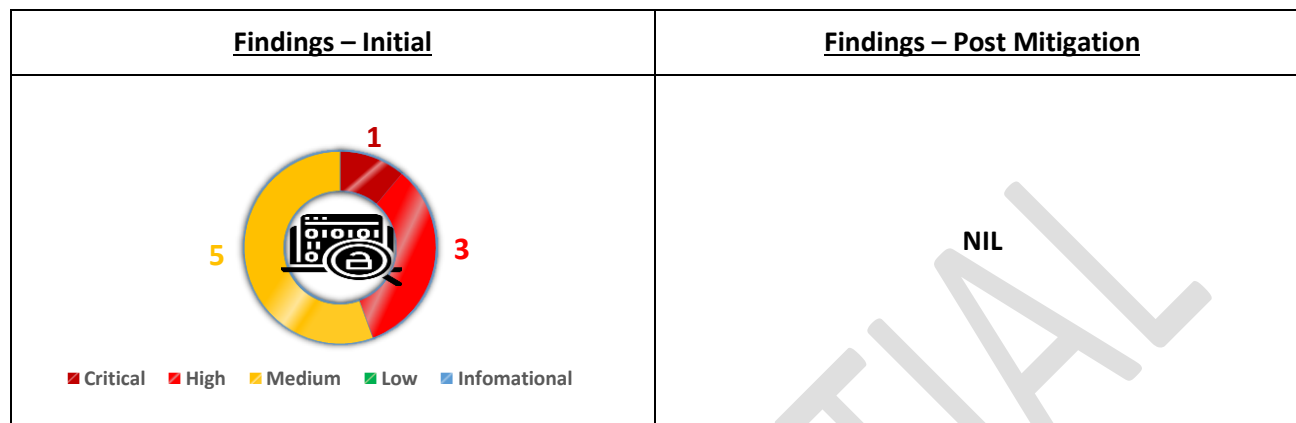
Assumptions

This report has been produced based on the output of the Security Assessment that was conducted on a particular date. All vulnerabilities have been highlighted in the report assuming that the utilities and other applications installed on the systems were being used for the business purpose, and accordingly the recommendation to mitigate those vulnerabilities have been made. It is, therefore, recommended that prior to acting on the recommendation, following actions are taken:

- Ascertain whether a service or application for which vulnerability has been identified and recommendation is made is actually required in the system for business purpose. In case there is no requirement of such services or applications, the same may be removed or disabled following an appropriate process. Else, the recommendations are applied on the system.
- Appropriate backup and rollback plan to be made prior to implementing the recommendation on the system.
- Vulnerabilities identified were as on the date testing conducted and also as per the scan policies (intrusive or non-intrusive) & plugins selected. There may be vulnerabilities which may exist and may not assess, since their exploits may lead to system downtime due to Denial of Service (DOS) attack. Also, the vulnerabilities identified after the scan date may also not form part of this report.
- Informing Vulnerabilities identified to Computer Emergency Response Team (CERT-In) as per directives

8. Executive Summary Report

8.1. IP wise vulnerability count



IP wise Vulnerability Count: Initial

Sl. No.	IP Address	Vulnerability Type					Total
		Critical	High	Medium	Low	Informational	
1	103.251.216.117	1	3	5	0	0	9
2	150.129.107.253	0	0	0	0	0	0
3	10.190.26.113	0	0	0	0	0	0
4	137.128.1.51	0	0	0	0	0	0
5	192.168.1.100	0	0	0	0	0	0
6	192.168.0.22	0	0	0	0	0	0
Overall Findings		1	3	5	0	0	9

IP wise Vulnerability Count: Post mitigation

Sl. No.	IP Address	Vulnerability Type					Total
		Critical	High	Medium	Low	Informational	
1	103.251.216.117	0	0	0	0	0	0
2	150.129.107.253	0	0	0	0	0	0
3	10.190.26.113	0	0	0	0	0	0
4	137.128.1.51	0	0	0	0	0	0
5	192.168.1.100	0	0	0	0	0	0
6	192.168.0.22	0	0	0	0	0	0
Overall Findings		0	0	0	0	0	0

9. Detail Report

1. IP: 103.251.216.117

Summary of findings:

Sl. No.	Vulnerability Name	Risk Level	CVSS Score	Revalidation Status
1	Microsoft SQL Server Unsupported Version Detection (remote check)	Critical	10	Fixed
2	SSL Version 2 and 3 Protocol Detection	High	7.5	Fixed
3	SSL Certificate Signed Using Weak Hashing Algorithm		7.5	Fixed
4	SSL Medium Strength Cipher Suites Supported (SWEET32)		7.5	Fixed
5	SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)	Medium	6.8	Fixed
6	SSL Certificate Cannot Be Trusted		6.5	Fixed
7	TLS Version 1.0 Protocol Detection		6.5	Fixed
8	SSL Self-Signed Certificate		6.4	Fixed
9	SSL RC4 Cipher Suites Supported (Bar Mitzvah)		5.9	Fixed

Open port details

Port	Service	Version
1433	tcp	ms-sql-s
1801	tcp	msmq
2103	tcp	zephyr-clt
2105	tcp	eklogin
2107	tcp	msmq-mgmt
2383	tcp	ms-olap4
49152	tcp	unknown
49153	tcp	unknown
49154	tcp	unknown
49155	tcp	unknown
49156	tcp	unknown
49157	tcp	unknown
49158	tcp	unknown
49161	tcp	unknown
49163	tcp	unknown
7070	tcp	realserver
7777	tcp	cbt
80	tcp	http

2. IP: 150.129.107.253

No vulnerability found

No open port found

3. IP: 10.190.26.113

No vulnerability found

Open port details

Port		Service	Version
2000	tcp	cisco-sccp?	
5060	tcp	sip?	

4. IP: 137.128.1.51

No vulnerability found

Open port details

Port		Service	Version
2000	tcp	cisco-sccp?	
3389	tcp	sip?	

5. IP: 192.168.1.100

No vulnerability found

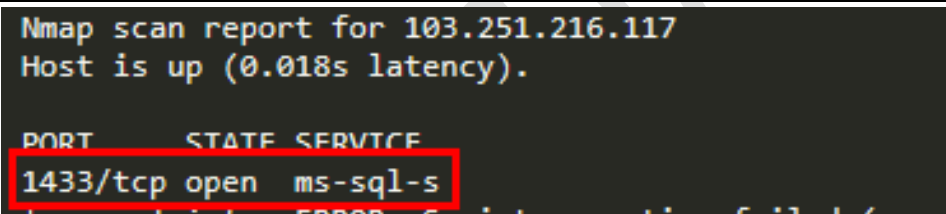
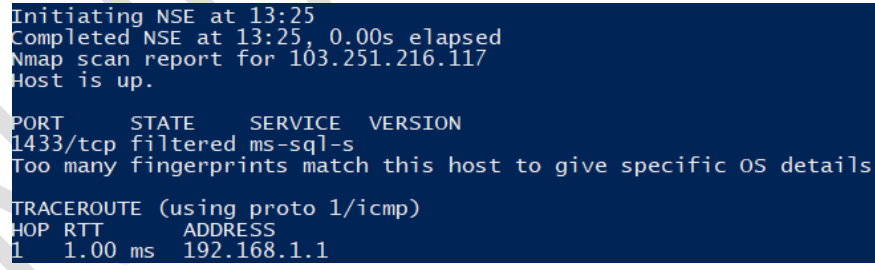
No open port found

6. IP: 192.168.0.22

No vulnerability found

No open port found

➤ Detail Findings:

1. Vulnerability Name: Microsoft SQL Server Unsupported Version Detection (remote check) Vulnerability Rating: Critical	
CVSS: 10	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Affected System:	103.251.216.117
Vulnerability Description:	According to its self-reported version number, the installation of Microsoft SQL Server on the remote host is no longer supported. Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities.
Impact:	An unsupported version of a database server is running on the remote host.
Proof of Concept:	 <pre> Nmap scan report for 103.251.216.117 Host is up (0.018s latency). PORT STATE SERVICE 1433/tcp open ms-sql-s </pre>
Remediation:	Upgrade to a version of Microsoft SQL Server that is currently supported. Reference Links http://www.nessus.org/u?d4418a57
Closure Remark: Fixed	 <pre> Initiating NSE at 13:25 Completed NSE at 13:25, 0.00s elapsed Nmap scan report for 103.251.216.117 Host is up. PORT STATE SERVICE VERSION 1433/tcp filtered ms-sql-s Too many fingerprints match this host to give specific OS details TRACEROUTE (using proto 1/icmp) HOP RTT ADDRESS 1 1.00 ms 192.168.1.1 </pre>

2. Vulnerability Name: SSL Version 2 and 3 Protocol Detection

Vulnerability Rating: High

CVSS: 7.5 CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Affected System: 103.251.216.117

Vulnerability Description:

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including: - An insecure padding scheme with CBC ciphers. - Insecure session renegotiation and resumption schemes. An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients. Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely. NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Impact:

The remote service encrypts traffic using a protocol with known weaknesses.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.026s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
1433/tcp  open  ms-sql-s
| ssl-enum-ciphers:
|   SSLv3:
|     ciphers:
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F
|       TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - F
|       TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - F
```

Remediation:

Consult the application's documentation to disable SSL 2.0 and 3.0. Use TLS 1.2 (with approved cipher suites) or higher instead.

Reference Links

<https://www.schneier.com/academic/paperfiles/paper-ssl.pdf>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<https://www.imperialviolet.org/2014/10/14/poodle.html>

Closure Remark: Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.

PORT      STATE SERVICE VERSION
1433/tcp  filtered ms-sql-s
Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT ADDRESS
1 1.00 ms 192.168.1.1
```

3. Vulnerability Name: SSL Certificate Signed Using Weak Hashing Algorithm

Vulnerability Rating: High

CVSS: 7.5 CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N **CVE-2004-2761 , CWE-310**

Affected System: 103.251.216.117

Vulnerability Description: The remote service uses an SSL certificate chain that has been signed using a cryptographically weak hashing algorithm (e.g. MD2, MD4, MD5, or SHA1). These signature algorithms are known to be vulnerable to collision attacks. An attacker can exploit this to generate another certificate with the same digital signature, allowing an attacker to masquerade as the affected service. Note that this plugin reports all SSL certificate chains signed with SHA-1 that expire after January 1, 2017 as vulnerable. This is in accordance with Google's gradual sunseting of the SHA-1 cryptographic hash algorithm. Note that certificates in the chain that are contained in the Nessus CA database (known_CA.inc) have been ignored.

Impact: An SSL certificate in the certificate chain has been signed using a weak hash algorithm.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.0072s latency).
Not shown: 960 closed tcp ports (reset)
PORT      STATE SERVICE
4/tcp     filtered unknown
22/tcp    filtered ssh
25/tcp    filtered smtp
80/tcp    open  http
85/tcp    filtered mit-ml-dev
111/tcp   filtered rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   filtered imap
445/tcp   filtered microsoft-ds
515/tcp   filtered printer
554/tcp   filtered rtsp
587/tcp   filtered submission
722/tcp   filtered unknown
1137/tcp  filtered trim
1433/tcp  open  ms-sql-s
| ssl-cert: Subject: commonName=WMSvc-SERVER
| Issuer: commonName=WMSvc-SERVER
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha1WithRSAEncryption
| Not valid before: 2021-05-25T11:56:03
| Not valid after: 2031-05-23T11:56:03
```

Remediation: Contact the Certificate Authority to have the SSL certificate reissued.

Reference Links

<https://tools.ietf.org/html/rfc3279>
<http://www.nessus.org/u?9bb87bf2>

Closure Remark:
Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.

PORT      STATE SERVICE VERSION
1433/tcp  filtered ms-sql-s
Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT ADDRESS
1 1.00 ms 192.168.1.1
```


4. Vulnerability Name: SSL Medium Strength Cipher Suites Supported (SWEET32)

Vulnerability Rating: High

CVSS: 7.5

CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVE-2016-2183

Affected System: 103.251.216.117

Vulnerability Description:

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite. Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Impact:

The remote service supports the use of medium strength SSL ciphers.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.026s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
1433/tcp  open  ms-sql-s
| ssl-enum-ciphers:
|   SSLv3:
|     ciphers:
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F
|       TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - F
|       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - F
|       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F
|       TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - F
|       TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - F
|     compressors:
|       NULL
|     cipher preference: server
|   warnings:
|     64-bit block cipher 3DES vulnerable to SWEET32 attack
```

Remediation:

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

Reference Links

<https://www.openssl.org/blog/blog/2016/08/24/sweet32/>
<https://sweet32.info>

Closure Remark: Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.
PORT      STATE SERVICE VERSION
1433/tcp  filtered ms-sql-s
Too many fingerprints match this host to give specific OS details
TRACEROUTE (using proto 1/icmp)
HOP RTT ADDRESS
1 1.00 ms 192.168.1.1
```

5. Vulnerability Name: SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)

Vulnerability Rating: Medium

CVSS: 6.8 CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:N/A:N **CVE-**2014-3566

Affected System: 103.251.216.117

Vulnerability Description: The remote host is affected by a man-in-the-middle (MitM) information disclosure vulnerability known as POODLE. The vulnerability is due to the way SSL 3.0 handles padding bytes when decrypting messages encrypted using block ciphers in cipher block chaining (CBC) mode. MitM attackers can decrypt a selected byte of a cipher text in as few as 256 tries if they are able to force a victim application to repeatedly send the same data over newly created SSL 3.0 connections. As long as a client and service both support SSLv3, a connection can be 'rolled back' to SSLv3, even if TLSv1 or newer is supported by the client and service. The TLS Fallback SCSV mechanism prevents 'version rollback' attacks without impacting legacy clients; however, it can only protect connections when the client and service support the mechanism. Sites that cannot disable SSLv3 immediately should enable this mechanism. This is a vulnerability in the SSLv3 specification, not in any particular SSL implementation. Disabling SSLv3 is the only way to completely mitigate the vulnerability.

Impact: It is possible to obtain sensitive information from the remote host with SSL/TLS-enabled services.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.023s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
445/tcp   filtered microsoft-ds
1433/tcp  open  ms-sql-s
| ssl-poodle:
| VULNERABLE:
|   SSL POODLE information leak
|   State: VULNERABLE
|   IDs: BID:70574 CVE:CVE-2014-3566
|   The SSL protocol 3.0, as used in OpenSSL through 1.0.1i
| and other
|   products, uses nondeterministic CBC padding, which makes
| it easier
|   for man-in-the-middle attackers to obtain cleartext data
| via a
|   padding-oracle attack, aka the "POODLE" issue.
| Disclosure date: 2014-10-14
```

Remediation: Disable SSLv3. Services that must support SSLv3 should enable the TLS Fallback SCSV mechanism until SSLv3 can be disabled.

Reference Links

<https://www.imperialviolet.org/2014/10/14/poodle.html>
<https://www.openssl.org/~bodo/ssl-poodle.pdf>
<https://tools.ietf.org/html/draft-ietf-tls-downgrade-scsv-00>

Closure Remark:
Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.

PORT      STATE SERVICE VERSION
1433/tcp  filtered ms-sql-s
Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT ADDRESS
1 1.00 ms 192.168.1.1
```

6. Vulnerability Name: SSL Certificate Cannot Be Trusted

Vulnerability Rating: Medium

CVSS: 6.5 CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Affected System: [103.251.216.117](#)

Vulnerability Description:

The server's X.509 certificate cannot be trusted. This situation can occur in three different ways, in which the chain of trust can be broken, as stated below : - First, the top of the certificate chain sent by the server might not be descended from a known public certificate authority. This can occur either when the top of the chain is an unrecognized, self-signed certificate, or when intermediate certificates are missing that would connect the top of the certificate chain to a known public certificate authority. - Second, the certificate chain may contain a certificate that is not valid at the time of the scan. This can occur either when the scan occurs before one of the certificate's 'notBefore' dates, or after one of the certificate's 'notAfter' dates. - Third, the certificate chain may contain a signature that either didn't match the certificate's information or could not be verified. Bad signatures can be fixed by getting the certificate with the bad signature to be re-signed by its issuer. Signatures that could not be verified are the result of the certificate's issuer using a signing algorithm that Nessus either does not support or does not recognize. If the remote host is a public host in production, any break in the chain makes it more difficult for users to verify the authenticity and identity of the web server. This could make it easier to carry out man-in-the-middle attacks against the remote host.

Impact:

The SSL certificate for this service cannot be trusted.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.0072s latency).
Not shown: 960 closed tcp ports (reset)
PORT      STATE SERVICE
4/tcp     filtered unknown
22/tcp    filtered ssh
25/tcp    filtered smtp
80/tcp    open  http
85/tcp    filtered mit-ml-dev
111/tcp   filtered rpcbind
135/tcp   filtered msrpc
139/tcp   filtered netbios-ssn
143/tcp   filtered imap
445/tcp   filtered microsoft-ds
515/tcp   filtered printer
554/tcp   filtered rtsp
587/tcp   filtered submission
722/tcp   filtered unknown
1137/tcp  filtered trim
1433/tcp  open  ms-sql-s
|
| ssl-cert: Subject: commonName=WMSvc-SERVER
| Issuer: commonName=WMSvc-SERVER
```

Remediation:

Purchase or generate a proper SSL certificate for this service.

Reference Links

<https://www.itu.int/rec/T-REC-X.509/en>
<https://en.wikipedia.org/wiki/X.509>

Closure Remark: Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.

PORT      STATE SERVICE VERSION
1433/tcp  filtered ms-sql-s
Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT ADDRESS
1 1.00 ms 192.168.1.1
```

7. Vulnerability Name: TLS Version 1.0 Protocol Detection

Vulnerability Rating: Medium

CVSS: 6.5 CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

Affected System: [103.251.216.117](#)

Vulnerability Description:

The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible. As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors. PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Impact:

The remote service encrypts traffic using an older version of TLS.

Proof of Concept:

```
Nmap scan report for 103.251.216.117
Host is up (0.026s latency).
Not shown: 978 closed tcp ports (reset)
PORT      STATE      SERVICE
80/tcp    open       http
135/tcp    filtered   msrpc
139/tcp    filtered   netbios-ssn
445/tcp    filtered   microsoft-ds
1433/tcp   open       ms-sql-s
| ssl-enum-ciphers:
| TLSv1.0:
|   ciphers:
|     TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - F
|     TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - F
|     TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - F
|     TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - F
|     TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F
|     TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - F
|     TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - F
```

Remediation:

Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Reference Links

<https://tools.ietf.org/html/draft-ietf-tls-oldversions-deprecate-00>

Closure Remark: Fixed

```
Initiating NSE at 13:25
Completed NSE at 13:25, 0.00s elapsed
Nmap scan report for 103.251.216.117
Host is up.

PORT      STATE      SERVICE  VERSION
1433/tcp   filtered   ms-sql-s

Too many fingerprints match this host to give specific OS details

TRACEROUTE (using proto 1/icmp)
HOP RTT      ADDRESS
1 1.00 ms 192.168.1.1
```

8. Vulnerability Name: SSL Self-Signed Certificate Vulnerability Rating: Medium	
CVSS: 6.4	CVSS:2/AV:N/AC:L/Au:N/C:P/I:P/A:N
Affected System:	103.251.216.117
Vulnerability Description:	The X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host. Note that this plugin does not check for certificate chains that end in a certificate that is not self-signed, but is signed by an unrecognized certificate authority.
Impact:	The SSL certificate chain for this service ends in an unrecognized self-signed certificate.
Proof of Concept:	<pre> 1801/tcp open msmq 2103/tcp open zephyr-clt 2105/tcp open eklogin 2107/tcp open msmsg-mgmt 2383/tcp open ms-olap4 3306/tcp filtered mysql 3389/tcp filtered ms-wbt-server 3546/tcp filtered unknown 5000/tcp filtered upnp 5221/tcp filtered 3exmp 7070/tcp open realserver ssl-cert: Subject: commonName=AnyDesk Client Issuer: commonName=AnyDesk Client </pre>
Remediation:	Purchase or generate a proper SSL certificate for this service.
Closure Remark: Fixed	<pre> Initiating NSE at 13:25 Completed NSE at 13:25, 0.00s elapsed Nmap scan report for 103.251.216.117 Host is up. PORT STATE SERVICE VERSION 1433/tcp filtered ms-sql-s Too many fingerprints match this host to give specific OS details TRACEROUTE (using proto 1/icmp) HOP RTT ADDRESS 1 1.00 ms 192.168.1.1 </pre>

9. Vulnerability Name: SSL RC4 Cipher Suites Supported (Bar Mitzvah) Vulnerability Rating: Medium	
CVSS: 5.9	CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N CVE- 2013-2566, 2015-2808
Affected System:	103.251.216.117
Vulnerability Description:	The remote host supports the use of RC4 in one or more cipher suites. The RC4 cipher is flawed in its generation of a pseudo-random stream of bytes so that a wide variety of small biases are introduced into the stream, decreasing its randomness. If plaintext is repeatedly encrypted (e.g., HTTP cookies), and an attacker is able to obtain many (i.e., tens of millions) ciphertexts, the attacker may be able to derive the plaintext.
Impact:	The remote service supports the use of the RC4 cipher.
Proof of Concept:	<pre> Nmap scan report for 103.251.216.117 Host is up (0.026s latency). Not shown: 978 closed tcp ports (reset) PORT STATE SERVICE 80/tcp open http 135/tcp filtered msrpc 139/tcp filtered netbios-ssn 445/tcp filtered microsoft-ds 1433/tcp open ms-sql-s ssl-enum-ciphers: SSLv3: ciphers: TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - F TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - F TLSv1.0: ciphers: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (secp256r1) - F TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (secp256r1) - F TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - F TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - F TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - F TLS_RSA_WITH_RC4_128_SHA (rsa 2048) - F TLS_RSA_WITH_RC4_128_MD5 (rsa 2048) - F compressors: NULL cipher preference: server warnings: 64-bit block cipher 3DES vulnerable to SWEET32 attack Broken cipher RC4 is deprecated by RFC 7465 </pre>
Remediation:	Only enable support for recommended cipher suites. Reference Links https://wiki.mozilla.org/Security/Server_Side_TLS https://ssl-config.mozilla.org/
Closure Remark: Fixed	<pre> Initiating NSE at 13:25 Completed NSE at 13:25, 0.00s elapsed Nmap scan report for 103.251.216.117 Host is up. PORT STATE SERVICE VERSION 1433/tcp filtered ms-sql-s Too many fingerprints match this host to give specific OS details TRACEROUTE (using proto 1/icmp) HOP RTT ADDRESS 1 1.00 ms 192.168.1.1 </pre>

10. About Prime

- Kolkata based Technology and Cyber Security focused enterprise for past 10 years
- Founded by a team of expert professionals with a large SI, Telecom, MNC and Govt. Background
- 700+ man Years Experience inside the team
- 150+ Clients spread out of India, Bangladesh, Africa, US, Latin America and UK
- ISO 9001, ISO 27001 Certified Enterprise with Govt. of India CERT Empanelment
- PMP Based Project Management and ITIL Based Service Operations
- Having Global NOC and SOC with 24x7 availability for managed services
- Best in class Tools for in NOC, SOC along with Certified Resources in multiple
- Member of NASCOM-DSCI, Infosec Foundation, TIE

11. Audit Test Standard



12. Team Skill Set



13. Cert Empanelment

भारत सरकार
GOVERNMENT OF INDIA
इलेक्ट्रॉनिकी और सूचना प्रौद्योगिकी मंत्रालय
MINISTRY OF ELECTRONICS & INFORMATION TECHNOLOGY
भारतीय कम्प्यूटर आपात प्रतिक्रिया दल (सर्ट-इन)
INDIAN COMPUTER EMERGENCY RESPONSE TEAM (CERT-IN)
इलेक्ट्रॉनिक्स निकेतन, 6, सी जी ओ कॉम्प्लेक्स, नई दिल्ली-110003
Electronics Niketan, 6, C G O Complex, New Delhi-110003
Website: www.cert-in.org.in

संख्या 3(15)/2004-CERT-In (Vol. XI)

No. 3(15)/2004-CERT-In (Vol. XI)

दिनांक 12.02.2021

Date: 12.02.2021

M/s Prime Infoserv LLP
60, Sibachal Road, Birati,
Kolkata-700051

Kind Attn: Mr. Sushobhan Mukherjee

Subject: Empanelment by CERT-In as an IT Security Auditing Organization

This refers to your request for empanelment along with (i) Consent form confirming acceptance of the terms and conditions of the empanelment (ii) Undertaking by your organisation on code of conduct (iii) Background verification certificate in respect of technical employees to be deployed for Information Security Auditing in Government and Critical Sectors.

It is to inform you that your organization has qualified all the required steps for empanelment. We are pleased to empanel 'M/s Prime Infoserv LLP' with validity up to 31st October 2023 as an Information Security Auditing Organization, for providing the **Information Security Auditing Services** in accordance with "The Terms and Conditions of Empanelment" as issued by CERT-In from time to time and published on CERT-In Website. M/s Prime Infoserv LLP shall be strictly compliant to all the terms and conditions of empanelment at all times.

We also invite your attention to the "Auditor Guidelines" & "Policy Guidelines for Handling Audit Related Data" issued by CERT-In (available on CERT-In website) and urge you to comply with the same. It may also be noted that it is **mandatory** to submit quarterly report and accurate data on time to CERT-In. The quality of audits carried out by CERT-In empanelled auditors is of utmost importance and need to be maintained at all times.

CERT-In reserves the right to terminate empanelment of the auditing organization (i) in case of non-compliance to any of CERT-In's terms & conditions and guidelines w.r.t empanelment being observed or reported by/to CERT-In (ii) Degradation of auditor's performance or competence as per CERT-In or on the basis of adverse feedback provided by auditee organization (iii) Non submission of quarterly report and data timely to CERT-In (iv) in case of involvement in any fraudulent or unethical activity.

A line of confirmation from your organization for the receipt of this letter and accepting its contents in true spirit may kindly be sent within the next 10 days.

Yours Sincerely,



(Dr. Sanjay Bhat)

Director General, CERT-In
Tel: 011-24368544



14. Contact Us

Office Contacts	Phone: +91 33 4008 5677 Email: support@primeinfoserv.com ; info@primeinfoserv.com
1st Level	Tamali Roy Phone: +91 8777833542 Email: tamali@primeinfoserv.in
2nd Level	Shampa Sengupta Phone: +91 99036 87873 Email: shampa@primeinfoserv.in
3rd Level	Sailen Sengupta Phone: +91 91637 00997 Email: ssengupta@primeinfoserv.com

Unlock the Values of NextGen Solution & Services

Accelerate your digital transformation journey with us.



**Cyber-Advisory | Compliance & Audit Services | Managed Security
Services**

Tel: +91 33 4008 5677 | Email: info@primeinfoserv.com | Web: www.primeinfoserv.com